Audit datové kvality podle IT Assurance Guide: Using COBIT - 3. díl

[1.3.2012] D. Pejčoch

Kritické zhodnocení použitelnosti IT Assurance Guide pro audit datové kvality

V rámci zpracování této studie jsem dospěl k řadě pochybností o praktické využitelnosti návodu IT Assurance Guide: Using COBIT pro účely auditu datové kvality. Především, IT Assurance Guide: Using COBIT se zdá být použitelný hlavně v případě, kdy firma přijala koncept IT Governance. V opačných případech zpravidla nebude řada kontrolních cílů sledována a proto bude v rámci auditu přeskočena. Vyjádření auditora v takovém případě bude zřejmě vždy obsahovat sáhodlouhý výčet doporučení, že je třeba tyto kontrolní cíle sledovat, než se dostane k meritu věci, tj. ke zhodnocení aktuálního stavu dat. Ke konvenčnímu stanovení úrovně vlastností dat na bázi jednotlivých atributů v rámci IT Assurance Guide dochází pouze až při stanovení dopadů úrovně kontrol. Zde by se potom zřejmě uplatnilo i provázání naměřené úrovně vlastností jednotlivých atributů přes jejich užití na související náklady, typické pro konvenční audity dat.

IT Assurance Guide se mi jeví jako příliš komplexní. Při pokusu o jeho konkrétní aplikaci popsaném v následující kapitole, jsem se nemohl ubránit dojmu, že se jedná o příslovečný „kanon na vrabce“. Jak uvádí [11], jeho aplikace vyžaduje od auditorů velkou schopnost vymezit a ohraničit předmět projektu ujištění a následně „vybrat ty doporučené kroky jednotlivých kontrol, které budou přínosem v kontextu business procesů dané organizace.“ Z uvedeného je zřejmé, že i jeho přizpůsobení pro účely auditu datové kvality by vyžadovalo značné schopnosti na straně auditora. Je zřejmé, že náklady auditu by za takové situace nebyly zrovna nízké. Problém by do značné míry vyřešil vznik dokumentu, který by toto přizpůsobení popisoval.

V přílišné komplexnosti lze však nalézt i jedno pozitivum. Běžnou praxí současnosti je, že audit datové kvality provádí dodavatel řešení pro její zlepšení. O nezávislosti takového auditu lze v takovém případě do značné míry pochybovat. Audit datové kvality je ze strany dodavatele často chápán spíše jako pre-sales aktivita před vlastní implementací řešení pro její zlepšení. Pokud by byl proces ujištění o kvalitě dat, resp. procesů jejich pořízení a transformace realizován pouze jako součást komplexního ujištění vztahujícího se na celé IT, dodávaného auditorskou společností, daly by se výsledky ujištění považovat za mnohem více nezávislé. Samozřejmě tedy za předpokladu, že auditorská společnost se nevěnuje jiným oblastem než auditu.

Nespornou výhodou IT Assurance Guide je hodnocení úrovně designu kontrol, které je v konvenčních auditech datové kvality opomíjeno. Konvenční přístupy uvažují procesy jako způsob, jakým lze dospět k prapůvodním příčinám chyb a k jejich konečným důsledkům. Slabiny těchto procesů však hodnotí až pokud naměří varující úroveň některé sledované vlastnosti dat. IT Assurance Guide postupuje obráceně. Nejprve nalezne nedostatek procesu (nedostatek v návrhu kontrolního cíle) a až poté určí jeho případné dopady do vlastností dat.

Při procházení jednotlivými kroky fází Plánování, Scoping a Realizace jsem se nemohl ubránit dojmu, že opakované vracení se k týmž oblastem jako je např. neustálá redefinice oblasti univerza, či hodnocených procesů a kontrolních cílů, by bylo v případě auditu datové kvality zbytečné. Nicméně, jak zmiňuje [11], na IT Assurance Guide je třeba pohlížet především jako na „bázi znalostí“, na jejímž základě si lze vytvořit své vlastní postupy. Je zde tedy reálná možnost redukce počtu redefinic na rozumnou míru.

Otázkou je, do jaké míry by pomohlo při použití IT Assurance Guide pro účely auditu datové kvality nahrazení COBITu jiným kontrolním rámcem. Pokud uvažujeme nekvalitní data jako operační riziko firmy, nabízel by se rámec COSO, který se používá pro budování integrovaného systému interních kontrol. Navíc by měl být podle [13] sladěn s COBIT, čímž by odpadl problém nekonzistence různých standardů použitích současně pro audit IS/IT. Nicméně, jak zmiňuje [11], COSO se kontrolám IS/IT věnuje pouze okrajově a jeho implementace se doporučuje provádět současně právě s COBIT. Z dalších standardů se ISO 27000 omezuje pouze na bezpečnost informací a ISO 9000 pouze na zdokumentování procesů.

Z pohledu auditu dat jsou z celé sady kontrol poskytovaných IT Assurance Guide nejzajímavější aplikační kontroly, které jsou specifické pro jednotlivé aplikace a nepokrývají je COBIT IT procesy. Jsou to ty kontroly, které by zůstaly v rámci IT Assurance Guide k dispozici i při náhradě COBITU jako kontrolního rámce rámcem jiným.

V případě bank by bylo vhodné konfrontovat kontrolní cíle COBITu s požadavky Basel II (resp. vznikajícího Basel III) na kvalitu dat. Otázkou je, do jaké míry Basel II podává konkrétní doporučení. [23] např. hovoří o tom, že data vstupující do modelů kreditního rizika mají být správná a „odpovídající svému účelu “. V jiné části dokumentu [23] se hovoří o nutnosti identifikace volatility dat a auditu správnosti, úplnosti, konzistentnosti, aktuálnosti a důvěryhodnosti datových zdrojů. Dokument se též vyjadřuje k nutnosti uchovávání historických dat a jejich použití v rámci modelů.

Obdobně v případě pojišťoven by bylo vhodné zvážit, zda kontrolní cíle COBITu nedoplnit o požadavky Solvency II. Tato regulace stejně jako Basel II uvažuje v rámci System of Governance řízení dat jako jednoho z největších operačních rizik firmy. Na úrovni Level1 (viz [24]) tato směrnice hovoří též o úplnosti, přesnosti a vhodnosti použitých údajů pro interní model. Na dalších úrovních bude zřejmě poněkud sdílnější. Level 2 (Implementing Measures) i Level 3 (doporučení) však dosud nemají svou konečnou podobu. Zprostředkovaně o požadavcích Solvency II na datovou kvalitu píše [25]. Zdůrazňuje význam kvalitních dat zejména pro interní modely. Zmiňuje zjeména tři vlastnosti: vhodnost, úplnost a správnost. Stejně tak jako v případě Basel II je kladen důraz i na uchování historických dat. [25] též zmiňuje význam porovnávání dat s externími zdroji za účelem ověření konzistence. S odvoláním na materiály CEIOPS (Committee of European Insurance and Occupational Pensions Supervisors) uvádí požadavky na transparentnost, granularitu, sběr historických dat a dohledatelnost dat. Obecně lze dle mého názrou doporučení CEIOPS ohledně datové kvality považovat za best practices z oblasti pojišťovnictví. V tomto směru [25] odkazuje na podrobnější zdroje CEIOPS [26], [27] a [28].

Pokud bych měl zmínit ještě další doporučené best practices, které je vhodné v rámci auditu datové kvality realizovat a IT Assurance Guide je vysloveně nezmiňuje, pak se rozhodně jedná o validaci adresních údajů proti územně identifikačním registrům. Zavedení těchto kontrol se zřejmě skrývá v COBIT kontrolních cílech PO2.1 Enterprise Information Architecture Model, resp. PO2.4 Integrity Managementm definice validačních pravidel v PO2.2 Enterprise Data Dictionary and Data Syntax Rules a monitoring v ME1.2 Definition and Collection of Monitoring Data. Nicméně i v případě, kdy tyto kontrolní cíle nejsou sledovány, v rámci auditu dat považuji tento krok za vhodný.

I za předpokladu, že nejsou sledovány kontrolní cíle PO3.3 Monitor Future Trends and Regulations a PO4.8 Responsibility for Risk, Security and Compliance,

považuji za vhodné provést ověření, zda jsou splněny požadavky zákona č. 101/2000 Sb., o ochraně osobních údajů a o změně dalších zákonů a v případě bank PCI DSS (Data Security Standard, viz [29]).

Praktický příklad assessmentu podle IT Assurance Guide

Přes některé uvedené výhrady k použití IT Assurance Guide: Using COBIT pro audit datové kvality se pokusím jeho praktické použití demonstrovat na konkrétním příkladu. Nejprve seznámím s architekturou auditované firmy – univerzální pojišťovny. Poté popíši praktickou náplň jednotlivých fází auditu dat podle IT Assurance Guide.

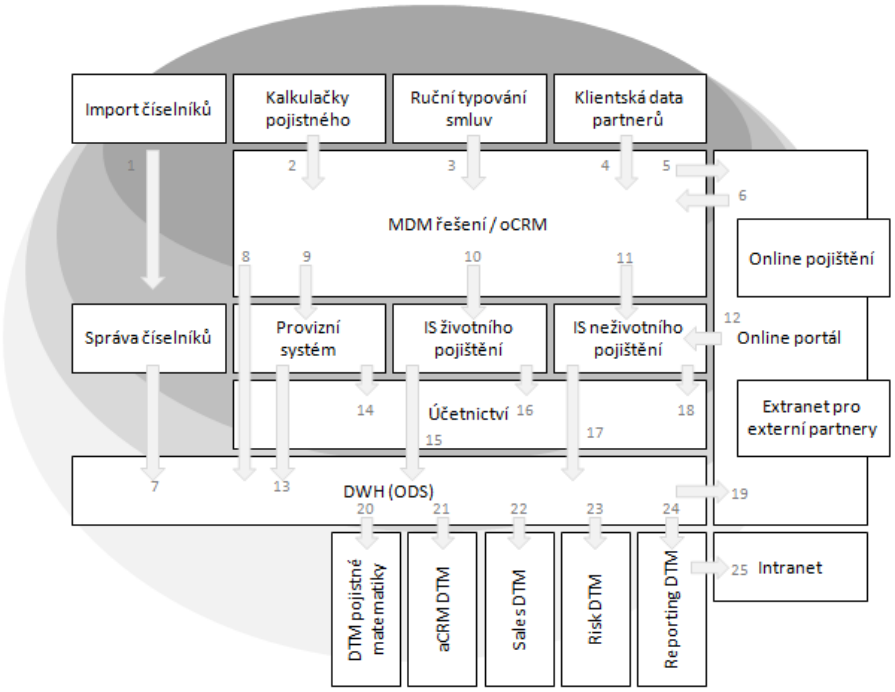
Popis architektury firmy použité v příkladu

Zkusme si pro účely praktického příkladu realizace auditu datové kvality představit následující univerzální pojišťovnu, která poskytuje pojistné produkty z těchto oblastí:

- neživotní pojištění (pojištění motorových vozidel, pojištění majetku a odpovědnosti, úrazové pojištění, pojištění podnikatelů, pojištění cestovních a léčebných výloh);
- životní pojištění (kapitálové, investiční, rizikové).

Architektura základních aplikací této pojišťovny je zachycena na obrázku č. 2. Obrázek znázorňuje idylický stav; v rámci modelového auditu budou zjištěny dílčí nedostatky . Do pojišťovny vstupují data jednak z externích číselníků a registrů (1) a jednak od externích partnerů jako jsou makléři a banky nabízející pojistné produkty v rámci finančních plánů (4). Standardně jsou pojistné smlouvy typovány buď ručně v rámci backoffice (3), anebo jsou dávkově přenášeny z kalkulaček pojistného nainstalovaných na noteboocích jednotlivých získatelů (2). Veškerá klientská data procházejí na vstupu procesem porovnávání se záznamy stávajících unifikovaných klientů. V případě zjištění dostatečné shody je příchozí klientský záznam sloučen s již existujícím. Kontrakty jednotlivých klientů jsou zpracovány v oddělených provozních systémech pro neživotní (11) a životní (10) pojištění. Separátně od těchto systémů je používán provizní systém (9). Aktualizace číselníků a dat z externích registrů jsou nahrávány do centrální správy číselníků (1), odkud jsou přenášeny do datového skladu (7). Data z primárních systémů životního a neživotního pojištění a provizního systému jsou dále přenášena do účetního systému (14,16,18) a datového skladu (13,15,17). Současně s nimi je do datového skladu přenášen i konsolidovaný klient (8). Na nejvyšší úrovni datového skladu jsou vystavěny data marty pro pojistnou matematiku (20), analytické CRM (21), Sales Management (22), řízení rizik (23) a reporting pro účely controllingu (24), které jsou dále publikovány na Intranetu (25). V rámci online portálu jsou jednak distribuována data pro externí partnery (5,19) a jednak je možné přes něj online sjednat vybrané typy pojištění . Při sjednávání pojištění probíhá porovnání klienta s master databází (6) a následně je nový kontrakt zanesen do IS neživotního pojištění (12).

Obrázek 2: Schéma IS architektury univerzální pojišťovny



Představme si nyní méně idylickou situaci, tj. že v architektuře pojišťovny zcela chybí MDM Hub centralizující kmenová data klientů. Vstupní kontroly duplicit jsou realizovány pouze na úrovni dvou oddělených provozních systémů. Online pojištění má svou vlastní datovou bázi a je s provozním systémem neživotního pojištění integrováno až v okamžiku, kdy dojde k platbě prvního pojistného. Klienti jsou v rámci aplikace pro online pojištění vždy nově zakládáni a stejně tak následně při jejich importu do systému neživotního pojištění. Provizní systém je napojen na oba systémy pro správu smluv, nicméně v rámci něj opět nedochází k deduplikaci klienta, neboť pro něj je stěžejní pohled přes jednotlivé získatele jednotlivých smluv, kteří mohou být u jednoho klienta rozdílní. K deduplikaci nedochází ani na úrovni datového skladu. Klient je na jeho úrovni definován na bázi identifikátoru z primárního systému, resp. rodného čísla / IČa.

Vedení této modelové pojišťovny se v nejmenovaném marketingovém časopisu dočetlo o úspěších své konkurenční pojišťovny v přímých kampaních. Rozhodlo se tedy též implementovat nástroj pro jejich řízení a za tímto účelem vytvořilo oddělení CRM, v jehož kompetenci řízení přímých kampaní bude. V rámci článku se též dočetlo, že jedním z kritických faktorů úspěšnosti implementace takového nástroje jsou kvalitní data. Rozhodlo se tedy povolat externího konzultanta v oboru datové kvality, aby zhodnotil stav jejích dat s ohledem na využití v rámci CRM.

Plánování auditu

V tomto případě je proces ujištění vztahem mezi IT co by stranou odpovědnou za stav kvality dat, externím auditorem co by profesionálem ujištění a oddělením CRM, které dostalo od vedení společnosti mandát být jeho zadavatelem (zainteresovanou stranou).

Externí auditor ve spolupráci s útvary IT a CRM při aplikaci horizontálního přístupu k definici základních parametrů univerza přes datové objekty identifikoval následující oblasti relevantní pro zamýšlené byznys procesy CRM:

- Klientská data (včetně adresních a kontaktních údajů);
- Data pojistných smluv;
- Data o předepsaném a zaplaceném pojistném v jednotlivých letech;
- Data o škodách a z nich plynoucího pojistného plnění;
- Parametry předmětu pojištění (např. motorového vozidla);
- Externí data popisující profily podle životního stylu.

Jelikož firma přijala principy IT Governance podle standardu COBIT, shodly se všechny zúčastněné strany na volbě této metodiky jako kontrolního rámce použitého v rámci procesu ujištění.

V souvislosti s analýzou rizik byla vytvořena hrubá matice užití atributů z datových zdrojů spadajících do univerza procesu ujištění. Znázorňuje ji tabulka č. 2. Pro účely rychlé analýzy rizika byla vytvořena na úrovni skupin atributů, v tomto případě na úrovni granularity definované atributem Doména.

Tabulka 2: Příklad matice užití jednotlivých atributů

Doména	Exekuce přímých kampaní				Podpůrné modely		
	Dožití ŽP	Up-sell	X-sell	Retence	Predikce storna	Predikce koupě	Hodnota klienta
KLIENT	A	A	A	A	A	A	A
KONTAKT	A	A	A	A			
SMLOUVA	A	A	A	A	A	A	A
ŠKODA			A				A
POJISTNE			A				A
PŘEDMĚT			A	A	A		
ZÍSKATEL	A	A	A	A			

Matice užití tvoří základ pro prioritizaci auditu jednotlivých atributů. K jednotlivým užitím jsou následně definovány v hrubé výši náklady, které mohou plynout z nedostatečné úrovně vlastností jednotlivých atributů / skupin atributů. Atributy jsou vztaženy k procesům pořízení dat a jejich transformací. Na základě výše nákladů jsou označeny procesy pořízení / zpracování dat, jejichž selhání přináší největší rizika. V případě modelové pojišťovny to jsou procesy pořízení a zpracování údajů klienta umožňujících jeho unifikaci, jeho adresních údajů, vybraných atributů smluv umožňujících identifikaci aktuální propojištěnosti a atributy popisující dosavadní škody a dispozice k nim (detaily předmětu pojištění), které mohou předurčit možné budoucí ztráty v případě chybného zacílení kampaně.

Dále následuje rychlý assessment jednotlivých procesů COBITu na „high-level“ úrovni. Pro znázornění výstupu assessmentu bylo použito jedno ze schémat uvedených pro tyto účely v [13]. Připomeňme, že závažnost procesu z pohledu rizika je hodnocena na škále od 1 (nejnižší) do 5 (nejvyšší), výkonnost procesu od 1 (velmi dobrá) do 5 (neznámá nebo špatná), „A“ / „N“ v případě místa realizace procesu, příznaku existující formalizace (ve smyslu existujícího kontraktu, SLA nebo zdokumentované procedury) a realizovaného monitoringu znamená výskyt nebo absence jevu. Posledním údajem matice je uvedení osoby zodpovědné za realizaci procesu. V případě, že proces COBITu není pro audit datové kvality na dané úrovni hierarchie řízení dat (v našem případě Data Governance) relevantní, uvádím u něj nulovou závažnost.

Tabulka 3: Zhodnocení zralosti procesů

Riziko		IT procesy	Realizace				Auditován	Formalizován	Zodpovědnost
Závažnost	Výkonnost		IT	Ostatní	Externí	Není známo			
0	4	PO1 Define a strategic IT plan	A	N	N	N	N	A	CIO
4	3	PO2 Define the information architecture	A	N	N	N	N	A	CIO
0	4	PO3 Determine technological direction	A	N	N	N	N	N	CIO
4	4	PO4 Define the IT processes, organisation and relationships	A	N	N	N	N	A	CIO
0	4	PO5 Manage the IT investment	A	N	N	N	N	A	CIO
1	4	PO6 Communicate management aims and direction	A	N	N	N	N	N	CIO
2	4	PO7 Manage IT human resources	N	A	N	N	A	A	Personální ředitel
5	2	PO8 Manage quality	A	N	N	N	A	A	Vedoucí oddělení řízení kvality
2	4	PO9 Assess and manage IT risks	A	N	N	N	N	A	CIO
2	4	PO10 Manage projects	N	A	N	N	N	A	Vedoucí úseku řízení projektů
0	3	AI1 Identify automated solutions	A	N	N	N	N	A	CIO
1	3	AI2 Acquire and maintain application infrastructure	A	N	N	N	N	A	CIO
1	3	AI3 Acquire and maintain technology infrastructure	A	N	N	N	N	A	CIO
1	3	AI4 Enable operation and use	A	N	N	N	N	A	CIO
2	3	AI5 Procure IT resources	A	N	N	N	N	A	CIO
1	4	AI6 Manage changes	A	N	N	N	N	A	CIO

1	4	AI7 Install and accredit solutions and changes	A	N	N	N	N	A	CIO
3	3	DS1 Define and manage service levels	N	A	N	N	N	A	Vedoucí oddělení nákupu
1	3	DS2 Manage third-party services	A	N	N	N	N	A	CIO
1	3	DS3 Manage performance and capacity	A	N	N	N	N	A	CIO
1	3	DS4 Ensure continuous service	A	N	N	N	N	N	CIO
3	4	DS5 Ensure system security	A	N	N	N	N	A	Oddělení compliance a security
3	3	DS6 Identify and allocate costs	A	N	N	N	N	A	CIO
4	5	DS7 Educate and train users	N	A	N	N	N	A	Personální ředitel
1	5	DS8 Manage service desk and incidents	A	N	N	N	A	A	CIO
1	5	DS9 Manage the configuration	A	N	N	N	N	A	CIO
2	5	DS10 Manage problems	A	N	N	N	N	A	CIO
5	3	DS11 Manage data	A	N	N	N	A	A	CIO
1	5	DS12 Manage the physical environment	A	N	N	N	A	A	CIO
1	5	DS13 Manage operations	A	N	N	N	N	A	CIO
3	3	ME1 Monitor and evaluate IT performance	A	N	N	N	A	A	CIO
5	3	ME2 Monitor and evaluate internal control	A	N	N	N	A	A	CIO
5	4	ME3 Ensure compliance with external requirements	A	N	N	N	N	A	CIO
0	4	ME4 Provide IT Governance	N	N	N	A	N	N	Board

Z uvedené matice je „překvapivě“ patrné, že je třeba audit zaměřit na procesy řízení dat, řízení kvality, monitoring kontrol a zajištění shody s externími požadavky (v tomto případě požadavky na data).

Stanovení rozsahu auditu

Na základě výstupů z předchozí fáze byly nejprve na základě schématu organizační struktury identifikováni pracovníci, spjatí jak po byznys stránce, tak po stránce IT s vymezeným předmětem ujištění. Byly identifikovány jejich role a odpovědnosti v souvislosti s tímto předmětem. Na základě interview s těmito zainteresovanými stranami (včetně pracovníků CRM oddělení) byly detailně vyspecifikovány požadavky na data a procesy, které je pořizují a transformují. Množina relevantních atributů byla určena konkretizací matice užití na úroveň jednotlivých atributů (viz Tabulka č. 4). Současně byla definována rizika spojená s nedodržením jednotlivých vlastností. Rizika byla popsána na základě své pravděpodobnosti výskytu a svého možného dopadu. Nejvýznamnější rizika se vztahovala k vlastnostem atributů klienta, vybraných kontaktních a adresních údajům klienta, data konce kontraktu a atributů popisujících předmět pojištění.

Tabulka 4: Matice užití na úrovni jednotlivých atributů

Doména	Označení atributu	Exekuce přímých kampaní				Podpůrné modely		
		Dožití ŽP	Up-sell	X-sell	Retence	Predikce storna	Predikce koupě	Hodnota klienta
KLIENT	Příznak nesouhlasu s oslovením	A	A	A	N	N	N	N
KLIENT	ID unikátního klienta	A	A	A	A	A	A	A
KLIENT	Role klienta na smlouvě	A	A	A	A	A	N	A
KLIENT	Titul před jménem	A	A	A	A	N	N	N
KLIENT	Jméno	A	A	A	A	N	N	N
KLIENT	Příjmení	A	A	A	A	N	N	N
KLIENT	Ulice + č.p. + č.or.	A	A	A	A	N	N	N
KLIENT	Obec	A	A	A	A	N	N	N
KLIENT	PSČ	A	A	A	A	A	A	A
KLIENT	Datum narození	A	A	N	A	A	A	A
KLIENT	Pohlaví	A	A	N	N	N	A	A
KONTAKT	Telefon	A	A	A	A	N	N	N
KONTAKT	E-mail	N	N	A	N	N	N	N
KONTAKT	Mobil	A	A	A	A	N	N	N
SMLOUVA	Druh storna	N	N	N	A	A	A	A
SMLOUVA	Datum vypracování návrhu	N	N	N	A	A	N	N
SMLOUVA	Datum počátku	A	A	A	A	A	A	A
SMLOUVA	Datum konce	N	N	A	N	A	N	A
SMLOUVA	Frekvence placení	N	A	A	N	A	N	N
SMLOUVA	Důvod storna	N	N	A	N	A	N	A
SMLOUVA	Roční pojistné celkem	A	A	A	N	A	N	A

SMLOUVA	Hodnota smlouvy ŽP	A	N	N	N	N	N	N
SMLOUVA	Příznak vinkulace	A	N	N	N	N	N	N
ŠKODA	Celkové plnění	N	N	N	N	N	N	A
ŠKODA	Datum hlášení	N	N	A	N	N	N	A
ŠKODA	Druh plnění	N	N	A	N	N	N	A
PŘEDMĚT	Rozhodná doba	N	N	A	N	N	N	N
PŘEDMĚT	Rok výroby vozidla	N	N	A	A	A	N	N
ZÍSKATEL	Stupeň kariery	A	A	A	A	N	N	N

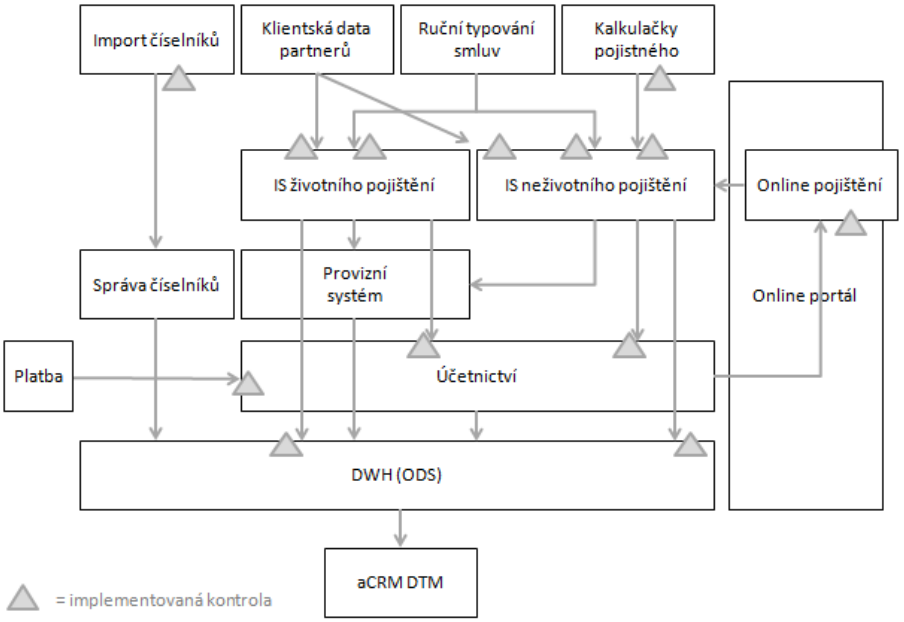
Současně byly identifikovány stávající politiky, procedury a z nich vyplývající kontroly zabezpečující dosahování požadované míry vlastností dat. Interview též ukázala, že zde v intervalu 1-2 let docházelo k ad-hoc prověřování datové kvality na bázi zjišťování kvantitativních (objektivních) vlastností dat vedoucích k jednorázovým nápravným opatřením, nikoliv však systematickým. Systematickým vstupním kontrolám v mnoha případech bránilo tvrzení obchodu (zejména ze strany agenturníků pracujících na IČO, disponujících profitabilními pojistnými kmeny), že by je vstupní kontroly zdržovaly a jsou plánovány na atributech, které nejsou podstatné.

V této fázi doporučuje IT Assurance Guide prolinkování byznys cílů na IT cíle a IT procesy. Pro tyto účely poskytuje COBIT v dodatku č. 1 matici mapující 17 generických byznys cílů na IT cíle (viz [40)]. My je pro naše účely nepoužijeme, neboť se v rámci uvažovaných cílů pohybujeme na větší úrovni granularity. Výsledkem této fáze je schéma enterprise architektury omezené na definovanou oblast univerza zobrazené na Obrázku č. 3 prolinkované na jednotlivé IT zdroje. Symbol trojúhelníku značí do „jisté míry“ prováděné kontroly.

V dalším kroku byly vybrány kontrolní cíle v návaznosti na kontrolní rámec COBIT. Paradoxně pro účely auditu datové kvality je nejzajímavějších 6 aplikačních kontrol, které jsou specifické pro jednotlivé aplikace a nejsou pokryty COBIT IT procesy.Ty testují implementaci nadefinovaných byznys kontrol vztahujících se k jednotlivým požadovaným vlastnostem informací (potažmo dat). Jedná se zejména o následující aplikační kontroly:

- AC2 Source Data Collection and Entry požadující vkládání dat autorizovanými a kvalifikovanými pracovníky a včasnou detekci chyb
- AC3 Accuracy, Completeness and Authenticity Checks
- AC4 Processing Integrity and Validity
- AC5 Output Review, Reconciliation and Error Handling vyžadující nastavení procedur a souvisejících odpovědností zajišťujících, že s výstupem je manipulováno autorizovaným způsobem, je doručen správným příjemcům a chráněn během přenosu

Obrázek 3: Schéma enterprise architektury



Z obecných kontrol založených na 34 COBIT procesech jsou pro modelový audit datové kvality nejrelevantnější ty související s procesem DS11 Manage Data, zejména:

- DS11.1 Business Requirements for Data Management požadující verifikaci, že pořizovaná a zpracovávaná data a výstupy zpracování splňují vlastnosti v míře požadované byznysem
- DS11.2 Storage and Retention Arrangements vyžadující definici a ipmlementaci procedur směřujících k efektivnímu a účinnému uložení dat, retenci a archivaci v souladu s byznys cíli, bezpečnostní politikou a regulatorními požadavky
- DS11.6 Security Requirements for Data Management vyžadující definici a implementaci politik a procedur pro identifikaci a aplikaci bezpečnostních požadavků

Z dalších kontrol jsou dále relevantní např.:

- PO2.1 Enterprise Information Architecture Model
- PO2.2 Enterprise Data Dictionary and Data Syntax Rules
- PO2.3 Data Classification Scheme (e.g. public, confidental, top secret)
- PO2.4 Integrity Management
- PO4.9 Data and System Ownership

- PO8.1 Quality Management System
- PO8.6 Quality Measurement, Monitoring and Review

IT Assuance Guide v následujícím kroku umožňuje customizaci vybraných kontrolních cílů. V našem příkladu (ale i v rámci použití kontrolních cílů pro audit datové kvality obecně) by bylo např. vhodné rozšířit kontrolní cíl aplikační kontroly AC3 Accuracy, Completness and Authenticity Checks (zjevně orientovaný na objektivní vlastnosti dat) i o měření dalších vlastností dat (např. pokrytí, u níž může být diskutabilní, zda ji v sobě neskrývá vlastnost „úplnost“). Pokud uvažujeme vlastnost „unikátnost“, není vhodné o ni rozšiřovat AC3 nebo jinou aplikační kontrolu, ale naopak je vhodné zjistit, zda tuto vlastnost v sobě neobsahuje některá obecná kontrola na úrovni některého z procesů COBITu. Především z toho důvodu, že unikátnost dat není specifikum jediné aplikace. Nalezneme ji v rámci procesu PO2 Define the Information Architecture v rámci kontroly PO2.1 Enterprise Information Architecture Model.

Realizace

V první fázi realizace ujištění je dle IT Assurance Guide vhodné se znovu ubezpečit o porozumění subjektu ujištění. V rámci této fáze provedl externí auditor řadu interview jejichž výsledkem byl plán aktivit, které budou realizovány. Nicméně se tato dodatečná interview nijak nedotkla původního rozsahu kontrolních cílů zařazených do scope projektu. Univerzem projektu zůstala část Enterprise architektury zobrazená na obr. 3 a kontrolní cíle v rámci kontrol AC2, AC3, AC4, AC5, DS11.1, DS11.2, DS11.6, PO2.1, PO2.2, PO2.3, PO2.4, PO4.9, PO8.1, PO8.6.

V dalším kroku provedl auditor test efektivnosti návrhu kontrol v rámci jednotlivých kontrolních cílů a test výstupu kontrolních cílů tam, kde se provádějí. Součástí testu byl jednak test návrhu kontrol, potvrzení, zda jsou skutečně realizovány a hodnocení jejich operativní efektivnosti a účinnosti. Test skutečné realizace mimo jiné ukázal, že na základě požadavku byznysu nejsou u všech atributů prováděny kontroly v rámci AC3 na vstupu z kalkulaček do provozního systému neživotního pojištění.

Příklad testu návrhu kontrol si ukážeme taktéž na aplikační kontrole AC3 Accuracy, Completness and Authenticity Checks. Na základě namátkového porovnání údajů vzorku dat v provozním systému neživotního pojištění, písemných smluv ze spisovny a údajů z vybraných registrů byly zjištěny vážné nedostatky v návrhu vstupních kontrol správnosti dat. Hypotézy se potvrdily při revizi designu konkrétní služby realizující import dat z kalkulaček pojistných smluv.V případě atributu rok výroby vozidla není prováděna validace údajů proti registru vozidel. Rok vozidla tak může obsahovat libovolný syntakticky správný údaj, v mnoha případech však ve skutečnosti rok vzniku pojistné smlouvy. V případě rozhodné doby není prováděna validace proti databázi škod. Problém nastává zejména při dokládání rozhodné doby místopřísežným prohlášením pojistníka. Další interview s uživateli ukázala, že aktuální výši bonusu je možné na základě požadavku obchodu měnit pod záminkou přidělení „mimořádného bonusu“ jako obchodní slevy na pojistném. Rovněž nedostatečné kontroly se ukázali být v případě importu adresních údajů. Vlivem absence kontrol proti registru UIR-ADR se na náhodně vybraných pojistných smlouvách generovaných kalkulačkami vyskytovaly zjevné nekonzistence mezi jednotlivými atributy adres. V mnoha případech bylo uvedeno pouze číslo popisné nebo číslo orientační, přičemž v dané lokalitě mohla záměna čísla popisného a čísla orientačního vést k nedoručitelnosti zásilky na danou adresu. Tam, kde byly kontroly nastaveny korektně, provedl auditor test jejich výstupu. Např. u verifikace rodného čísla a kontroly konzistentnosti mezi ním, uvedeným pohlavím a datem narození tato kontrola vedla k zjištění, že validační proces zaloguje cca 10% záznamů jako nevalidní RČ nekonzistentní s „odvozenými“ atributy. Ve většině případů se jednalo o atributy cizinců bez trvalého pobytu v ČR. Tento log je dále zpracováván oddělením zákaznické podpory, které verifikuje, zda se skutečně jedná o cizince, či ne.

V předposledním kroku fáze realizace ujištění jsou zdokumentovány dopady zjištěných slabin kontrol, zejména do byznysu. Požadavek na zjištění byznys dopadu dle [13] často vede k dalším dodatečným analýzám. K nim je nutné se uchýlit v případě, kdy pro zhodnocení dopadu v rámci prováděných kontrol chybí metriky, kontroly fungují špatně nebo byly aplikovány nekonzistentně. Mezi konkrétními příklady analýz, které tento zdroj uvádí, figurují nám již známé přístupy praktikované v rámci konvečních přístupů k auditu datové kvality jako jsou např. anekdoty z vertikály, cause-effect analýzy či mapování dopadu do byznys procesů. Jako příklad konkrétní situace je možné zmínit namapování důsledků cca 2% výskytu chybějících či nevalidních adresních údajů na byznys procesy relevantní pro CRM. Zjištěné nedostatky byly ohodnoceny z pohledu přímých ekonomických důsledků ročními náklady cca 360 tis.

V posledním kroku realizace je formulován závěr a doporučení. Ta je vhodné doplnit porovnáním slabin s dotazy na základě root-cause analýzy, benchmarkingem a maturity modelem pro interní kontroly. Doporučení mají formu konkrétních akcí směřujících ke snížení dopadu slabostí kontrol, porovnáním výkonnosti se standardy a nejlepšími praktikami. V rámci doporučení auditor uvedl zejména nutnost zajištění jednotného pohledu na unifikovaného a deduplikovaného klienta, nutnost zavedení kontrol proti územně identifikačnímu registru UIR-ADR, databázi škod a registru vozidel. V případě zmiňovaného návrhu kontroly RČ auditor doporučil rozšířit kontrolu tak, aby zohledňovala místo narození. Tato změna by vedla k menšímu zatížení backoffice, neboť korektně nekonzistentní údaje cizinců by nebyly logovány.

Návrh struktury zprávy auditora pro účely auditu datové kvality

Formálním výsledkem činnosti auditora by měla být výstupní auditorská zpráva. Příloha č. 1 obsahuje návrh šablony použitelné pro audit datové kvality. Při její tvorbě jsem se inspiroval požadavky, které na formální náležitosti klade §20 zák. 93/2009 Sb. o auditorech, standard S7-Reporting a návod G20-Reporing publikovanými ISACA. Podle uvedeného zákona zpráva musí obsahovat identifikaci auditora, vymezení rozsahu auditu, odkaz na relevantní standardy, výrok auditora, popis skutečností relevantních k výroku, datum vyhotovení a podpis. Pro účely auditu datové kvality byly převzaty všechny požadované části s výjimkou výroku auditora, který v našem případně použít nelze. Auditor se podle §20 odst. 1 c) zák. 93/2009 Sb. vyjadřuje ke shodě reality s účetní závěrkou a jeho výrok může nabývat pouze těchto hodnot: (1) bez výhrad, (2) záporný výrok, (3) s výhradami, (4) odmítnutí výroku.

Standard S7 (viz [17]) vyžaduje tyto formální součásti zprávy auditora: (1) identifikace organizace, kde byl audit realizován, (2) vymezení rozsahu, (3) definici cíle, (4) vymezení doby po kterou se audit prováděl, (5) vymezení způsobu auditu, (6) uvedení hloubky auditu, (7) uvedení časového rozvruhu prováděných činností, (8) uvedení závěrů, nálezů a doporučení a konečně (9) uvedení všech omezení při provádění auditu. Šablona v příloze č. 1 obsahuje všechny tyto části.

Návod G20 (viz [18]) odkazující se na standard S7 doporučuje tyto formální části: (1) název zprávy, (2) identifikace adresáta, (3) popis rozsahu auditu (identifikace / popis objektů auditu, použitá kritéria hodnocení), (4) účel zprávy, (5) identifikace uživatelů zprávy, (6) omezení užití, (7) omezení při realizaci auditu, (8) doporučení opravných akcí a reakce odpovědných managerů na toto doporučení, (9) názor auditora na efektivnost kontrol, (10) podpis, adresa, datum zpracování zprávy a konečně (11) ustanovení, že audit byl vykonán v souladu s ISACA IT Audit and Assurance Standards nebo dalšími profesními standardy. Všechna tato doporučení byla zohledněna v šabloně auditu v příloze č. 1.

Kromě výše uvedených požadavků v sobě šablona zohledňuje i další standardní komponenty, s nimiž jsem se setkal v praxi u dokumentů typu „assessment datové kvality“, tj.: (1) historie a verze dokumentu, (2) identifikace tvůrce a revidujících osob, (3) manažerské shrnutí, (4) popis metodiky auditu, (5) terminologický slovník.

Závěry

IT Assurance Guide jako takový dle mého názoru lze aplikovat pro realizaci auditu datové kvality. Jedná se o posloupnost činností, kterou lze (jak ukazuje příloha č. 2) do značné míry namapovat na kroky doporučené v rámci konvenčních přístupů k auditu datové kvality. Některé opakované návraty k redefinici scope bude účelné v rámci aplikace na audit datové kvality vynechat. Jako problematická se může jevit volba COBITu jako kontrolního rámce a to zejména za situace, kdy auditovaný subjekt nepřijal principy IT Governance. Nicméně pro účely auditu datové kvality jsem jiný vhodný komplexní rámec nenalezl. Pro účely některých regulací by bylo zřejmě vhodné kontrolní cíle COBITu doplnit o kontrolní cíle požadované těmito regulacemi. Procesní kontroly doporučované IT Assurance Guide: Using COBIT jsou natolik komplexní, že je značně diskutabilní, zda se v případě malých auditů nejedná o příslovečný „kanon na vrabce“. Metodiky dosud považované v rámci auditu dat za komplexní, jako je např. TQdM (Total Quality Data Management) Larryho Englishe, se v porovnání s IT Assurance Guide jeví jako titěrné, už s ohledem na fakt, že odpovídají pouze podmnožině jeho kroků.

Seznam použité literatury

- [1] BATINI, Carlo, SCANNAPIECO, Monica. Data Quality: Concepts, Methodologies and Techniques. Berlin: Springer-Verlag, 2006. xix, 262 s. ISBN-10 3-540-33172-7.
- [2] DYCHÉ, Jill, LEVY, Evan. Customer data integration: Reaching a Single Version of the Truth. SAS Institute Inc., Wiley & Sons, 2006, xxiv, 294 s. ISBN-10 0-471-91697-8.
- [3] ENGLISH, Larry P. Improving Data Warehouse and Business Information Quality: Methods for Reducing Costs and Increasing Profits. Wiley & Sons, 1999. xxvi, 518 s. ISBN-10 0-471-25383-9.
- [4] KRÁL J., ŽEMLIČKA M. Kvalita dat a informací – základní omezení IT ve veřejné správě, Systems Integration 2006, str. 215 – 222.
- [5] LEE, Yang W., PIPINO, Leo L., FUNK, James D., WANG, Richard Y. Journey to Data Quality. The MIT Press, 2006. 240 s. ISBN-10 02-621-2287-1.
- [6] LOSHIN, D. The Practitioner’s Guide to Data Quality Improvement. Burlington: Morgan Kaufmann as inprint of Elsevier, 2011. ISBN 978-0-12-373717-5.
- [7] McGILVRAY, D. Executing Data Quality Projects: Ten Steps to Quality Data and Trusted Information. Morgan Kaufmann, 2008. xviii, 325 s. ISBN 978-0-12-374369-5.
- [8] PIPINO, L., LEE, Y. W., WANG, R.Y. Data quality assessment. Communications of the ACM 45(4) (2002). 211-218.
- REDMAN, T. Data Quality: The Field Guide. Boston: Butterworth-Heinemann MA, 2001. xviii, 241. ISBN-10 1-55558-251-6.
- ZELENÝ M.: Management Support Systems: Towards Integrated Knowledge Management. Human Systems Management, Vol. 7 no. 1 (1987) 59 – 70.
- SVATÁ, V. Audit informačního systému. Příbram: Professional Publishing, 2011. ISBN 978-80-7431-034-8.
- COBIT 4.1. Rolling Meadows: IT Governance Institute, 2007.
- IT assurance guide: using COBIT. Rolling Meadows: IT Governance Institute, 2007. ISBN 978-1-933284-74-3.
- ISACA. COBIT 5 Initiative—Status Update [online]. [© 2012] [cit. 2012-01-14]. Dostupné pod odkazem: http://www.isaca.org/Knowledge-Center/cobit/Pages /COBIT-5-Initiative-Status-Update.aspx
- COBIT® 5 Design (Exposure Draft), ISACA, isaca.org, 2010.
- SKLENÁK, V. a kol. Data, informace, znalosti a Internet. Praha: C. H. Beck 2001. ISBN 80-7179-409-0.
- ISACA. IS AUDITING STANDARD REPORTING DOCUMENT #S7 [online].[@2004][cit. 2012-01-22]. Dostupné na: http://www.isaca.org/Knowledge-Center /Standards/Documents/Audit%20Standards/S7ReportingStandardRevised2Mar05.pdf
- ISACA. IT AUDIT AND ASSURANCE GUIDELINE G20 Reporting [online]. [@2003, 2010][cit. 2012-01-22]. Dostupné na: http://www.isaca.org/Knowledge-Center/Standards/Documents/G20-Reporting-13Aug2010.pdf
- Zákon 93/2009 Sb. o auditorech a o změně některých zákonů (zákon o auditorech).
- Line of business [online]. [cit. 2011-01-24]. Wikipedie : otevřená encyklopedie. Dostupné z WWW: .
- Data Quality Assurance and Control Guidelines [online]. Business Intelligence and Performance Management Institute. Dostupné na: .
- Informatica. Data Quality in Risk Management and Basel II [online]. [June 2009][cit. 2012-01-26] Dostupné na: http://www.informatica.com/downloads /6964_dq_riskmanbasel_wp_web.pdf
- Basel Committee on Banking Supervision, International Convergence of Capital Measurement and Capital Standards, A Revised Framework, June 2004.
- SMĚRNICE EVROPSKÉHO PARLAMENTU A RADY 2009/138/ES [online]. [2009-11-25][cit. 2012-01-26]. Dostupné na: http://register.consilium.europa.eu /pdf/cs/09/st03/st03643-re06.cs09.pdf
- Moody’s Analytics. Meeting the Data Quality Management Challenges of Solvency II [online]. [May 2011][cit. 2012-01-26] Dostupné na: http://www.moodysanalytics.com/Contact-Us/ERM/Contact-Form-Solvency-II-Whitepaper/~/media/Microsites/ERM/Solvency-II-Whitepaper/MA-DataQualityManagement-FINAL.ashx
- CEIOPS (CP 43/09), “Consultation Paper No. 43, Draft CEIOPS’ Advice for Level 2 Implementing Measures on Solvency II: Technical Provisions – Article 85 f, Standards for Data Quality,” 2 July 2009
- CEIOPS (43/09), “CEIOPS Advice for Level 2 Implementing Measures on Solvency II:Technical Provisions – Standard for Data Quality,” former CP 43, https://eiopa.europa.eu/fileadmin/tx_dam/files/consultations/consultationpapers/CP43/CEIOPS-CP-43-09-L2-Advice-TP-Standards-for-data-quality.pdf
- CEIOPS-SEC (106/09), “Summary of Comments on CEIOPS-CP-43/09 Consultation Paper on the Draft L2 Advice on TP - Standards for Data Quality,”https://eiopa.europa.eu/fileadmin/tx_dam/files/consultations/consultationpapers/CP43/CEIOPS-SEC-106-09-Comments-and-Resolutions-Template-on-CEIOPS-CP-43-09.pdf
- PCI. PCI SSC Data Security Standards Overview [online]. [© 2006 - 2012][cit. 2011-02-27]. Dostupné na: https://www.pcisecuritystandards.org /security_standards/

Přílohy

- Příloha č. 1: Šablona dokumentu Data Quality Assessment: Zpráva auditora
- Příloha č. 2: Matice mapující známé přístupy k auditu datové kvality na kroky IT Assurance Guide
- Příloha č. 3: Kontroly podle IT Assurance Guide

Komentáře ke článku

Powered by HOLOPAGE
©2011 - 2021 D. Pejčoch